TRC Review | NovaPay Zero-Downtime CI/CD

Project 1A · Aditi Chandra · 14 October 2026

Review purpose

- Review the target release design, local demonstration, security controls, and remaining evidence before submission.

Project boundary

- Fictional banking simulator. No real payment processing, customer data, production credentials, or cloud deployment is connected.

Requested decision

- Review architecture and thresholds; agree the smallest approved local demonstration path; assign owners for remaining proof.

Status

- Design artifacts assembled. Operational cloud evidence is pending; this deck does not claim production readiness.

Executive summary

A phased design with an honest evidence boundary

What is ready to review

- Eight-stage architecture and stage specifications
- Blue-green/canary, compliance, migration, promotion, rollback, runbooks, observability

What works locally

- Java simulator and scripts
- Helm blue-green model and OPA policy examples
- Local source/build workflow definition

What is not demonstrated

- No running registry, Kubernetes, Istio, database, DAST target, or Prometheus/Grafana stack
- No verified production promotion or DORA measurements

Recommendation

- Approve the design as an assessment draft; complete one local, synthetic end-to-end gate demonstration before making operational claims.

Eight-stage pipeline architecture

Each blocking stage preserves source and artifact identity

Stages 1–4

- 1. Source control and trigger: reviewed change, protected branch, source SHA
- 2. Build and compile: Java 21, reproducible artifact, build metadata
- 3. Static analysis and SAST: source rules, severity gates
- 4. Dependency scan and SBOM: Trivy/Syft, digest and inventory

Stages 5–8

- 5. Integration and contract checks: API compatibility and synthetic test data
- 6. DAST: isolated target; block Critical/High findings
- 7. Policy and compliance: OPA, approvals, immutable audit record
- 8. Deploy and verify: blue-green, phased canary, hold or rollback

Release identity

- One source SHA, immutable image digest, SBOM digest, and evidence chain follow the release.
- Eight stages are sequential in this draft: 63-minute non-production target; production bake is 24 hours.

Evidence

- Editable Draw.io source, PNG export, and per-stage specifications are included.

Compliance and audit gates

Seven gates block release on missing or failed evidence

Security gates

- SAST: zero Critical, at most two High, line coverage ≥80%, branch coverage ≥70%
- DAST: zero Critical and High
- Dependency/image/SBOM: block Critical and High CVSS >8.0; immutable digest

Platform and change gates

- License review for restricted licenses
- OPA Kubernetes policy: approved digest, non-root, no privileged containers, resource requests/limits
- IaC policy and complete change/audit evidence

Exceptions

- Finding- and digest-specific, independently approved, time-limited, recorded, and expired closed.
- No production exception for Critical vulnerabilities, privileged containers, missing approval, or missing audit evidence.

Threshold discrepancy

- The PDF gives different High/CVSS wording. Draft uses the stricter >8.0 release block; 72 hours is remediation SLA only for lower, non-blocking findings.

Blue-green and canary release

Preserve the last-known-good slot while traffic increases gradually

Blue-green

- Validate idle slot and digest; deploy candidate; run preview synthetic checks; approve route change; drain and observe.
- Use shared session handling and idempotency for payment-like simulation work.

Canary phases

- 1–2% for 15 min: error <0.1%, p99 <200 ms
- 5–10% for 30 min: error <0.05%, no Critical alerts
- 25–50% for 60 min: all SLOs pass
- 100%: 24-hour bake

Decision rule

- Compare with rolling 7-day baseline; Welch t-test and chi-squared error comparison; 95% confidence interval.
- Missing/insufficient data or inconclusive statistics means HOLD.

Evidence limit

- Current scripts evaluate supplied values and prepare a plan; they do not route live traffic or calculate statistical tests.

Database migration safety

Keep old and new application versions compatible during rollout

Expand

- Add nullable fields/tables/indexes without removing the current interface.
- Review migration checksum and use least-privilege migration identity.

Migrate and verify

- Backfill in bounded, restartable batches; monitor load, lock time, and lag.
- Verify counts, null rates, constraints, and business invariants before switching reads/writes.

Contract

- Remove obsolete schema only in a later approved release after the rollback window and restore verification.

Current state

- The simulator has no database or migration framework. PostgreSQL/Flyway is a design target, not an executed migration.

Four-environment promotion

Promote the same immutable digest

Dev → staging

- Dev: automatic after reviewed merge; synthetic data; startup and policy checks.
- Staging: integration, contract, DAST, compatibility, and synthetic transaction checks.

Pre-production → production

- Pre-production: production-like load, migration rehearsal, rollback and alert checks.
- Production: named approval, blue-green switch, phased canary, 24-hour bake.

Promotion invariants

- Same image digest across environments; configuration revisions reviewed separately.
- Digest change, missing gate result, expired exception, or failed evidence restarts/blocks promotion.

Current state

- Four actual environments and independent approval identities are not configured.

Rollback and incident handling

Three trigger categories lead to an eight-step recovery

Immediate Category A

- HTTP 5xx ≥5% for 2 min; exhausted DB pool; suspected corruption/duplicate processing; confirmed compromise; gateway timeout ≥35%.
- Freeze canary and route to last known-good target immediately.

Category B / C

- B: error ≥1% for 5 min, p99 ≥200 ms or 2× baseline, sustained readiness/queue issue: hold, investigate up to 15 min, then roll back if persistent.
- C: inconclusive canary or missing telemetry: hold; never treat absence as pass.

Recovery sequence

- Capture → freeze → protect in-flight work → select prior digest → restore route → verify health → reconcile → preserve and review evidence.

Simulation

- Friday SEV-1 script is fictional and prints a timeline; it does not alter traffic or process real payments.

Observability and DORA

Show verified measurements only

Operational signals

- Availability, HTTP 5xx, p99, database pool, queue age, synthetic checks, canary sample count and confidence interval.

DORA definitions

- Deployment frequency: successful production promotions per week
- Lead time: first commit to verified production promotion
- Change failure rate: rollback/hotfix/incident deployments ÷ all production deployments
- Time to restore: incident trigger to verified stable recovery

Status

- Targets are documented; measured values are N/A because no production events or live metrics exist.
- Grafana dashboard JSON, SVG mockup, and example Prometheus alert rules are included.

Privacy

- Use synthetic traffic; avoid sensitive identifiers and secrets in logs and metric labels.

Assessment evidence and gaps

Design and local evidence are distinct

Available in repository

- Architecture, editable diagram, eight stage specs, deployment/gate/migration/promotion/rollback docs
- Runbooks, local scripts, Helm chart, OPA examples, dashboard artifacts, self-assessment, reflection draft

Evidence still needed

- GitHub Actions run pending; local check logs are captured.
- Built image scan and SBOM tied to an immutable digest
- Demonstrated deployment, canary, rollback, DAST, metrics, approvals, and migration behavior

Environment constraint

- No working local container engine/Kubernetes configured. User instructions prohibit software installation without explicit permission.

Submission caution

- Do not present mockups, proposed thresholds, or fictional incident outputs as live operational proof.

TRC decisions and next evidence

Keep Project 1A time-bound and reviewable

Review requests

- Review the stricter dependency threshold interpretation and proposed operational thresholds.
- Confirm the exact hand-in folder/repository naming expected by the assessor.
- Approve the narrow local runtime path needed for a container/cluster demonstration, if required.

Next evidence sequence

- Run GitHub Actions and archive its result.
- Resolve chart findings and use a real image digest.
- Build and scan the container image.
- Demonstrate rollout/rollback; connect metrics and update evidence.

Project scope

- Project 1A remains the active 10-day task. Project 1C stays deferred.

Decision

- TRC review requested. Owner review and approval are pending; no external transfer or email has been performed.